Course - 2

Manage security risk

1. Modules 1 :- security domain
2. Module 2 security framework and control
3. Module - 3 → Introduction to tools
4. Module - 4 → Playbook and respond to incident

1 Module - 1

security posture :- An Organization ability to manage its defense of critical asset and data and react to change

Security management

Risk mitigation : the process of having the right procedure and rules in place to quickly reduce the impact of a risk like a breach

Business continuity

an organization's ability to maintain their everyday productivity by establishing risk disaster recovery plan

Asset Security

Focus Both

Digital Physical

also related to storage maintains retention and destruction of data

Security architecture and engeering

focus on data optimize security
By tool, systems and processes are
in place to protect an organizatiy
asset and data

Share responsibility
all individuals within an organisat
take active role in low
risks Both physical & virtual

Comms and Network Security
focus on managing and securing
physical network & wireless com

Identity and access management
access and authorization to keep
data secure by polici.

- ID
- Authentication
- Authorization
- accountability

Security assessment and testing
focus on security control

Security operation
Implement preventive measure

software dev security

secure coding Practice

- Threat Risk and Vulnerability

threats -> Any circumstance or event that can negatively impact assets
- social Engineering
- Phishing

Risk -> anything that can impact confidentiality integrity or availability of asset

Low risk asset :- would not harm operation, financial and reputation

medium risk :- not available to public
some damage
Ex - early release

High risk : protected by law severe impact any way to company

- vulnerability : A weakness that can be exploited by a threat
Ex → outdated firewall, app, weak password.

Key impact

1. financial impact
2. Identity Theft

② Reputation

NIST risk management framework

- Prepare
  activity that are necessary to manage security and privacy risk before breach occurs

- Categorize
  used to develop risk management processes & task

- Implement
  Implement security and privacy plans for the organization

- Assess
  Determine if implemented policy is meeting organization needs

- Authorize
  being accountable

- monitore
  - Be aware how system are operating

Terms and definitions from Course 2, Module 1

Assess: The fifth step of the NIST RMF that means to determine if established controls are implemented correctly

Authorize: The sixth step of the NIST RMF that refers to being accountable for the security and privacy risks that may exist in an organization

Business continuity: An organization's ability to maintain their everyday productivity by establishing risk disaster recovery plans

Categorize: The second step of the NIST RMF that is used to develop risk management processes and tasks

External threat: Anything outside the organization that has the potential to harm organizational assets

Implement: The fourth step of the NIST RMF that means to implement security and privacy plans for an organization

Internal threat: A current or former employee, external vendor, or trusted partner who poses a security risk

Monitor: The seventh step of the NIST RMF that means be aware of how systems are operating

Prepare: The first step of the NIST RMF related to activities that are necessary to manage security and privacy risks before a breach occurs

Ransomware: A malicious attack where threat actors encrypt an organization's data and demand payment to restore access

Risk: Anything that can impact the confidentiality, integrity, or availability of an asset

Risk mitigation: The process of having the right procedures and rules in place to quickly reduce the impact of a risk like a breach

Security posture: An organization's ability to manage its defense of critical assets and data and react to change

Select: The third step of the NIST RMF that means to choose, customize, and capture documentation of the controls that protect an organization

Shared responsibility: The idea that all individuals within an organization take an active role in lowering risk and maintaining both physical and virtual security

Social engineering: A manipulation technique that exploits human error to gain private information, access, or valuables

Vulnerability: A weakness that can be exploited by a threat

Module - 2

- Frame work
- control
- Design Principal
- security audit

Framework

guideline use for building plan to help mitigate risk and threat to data and privacy

Controls

used to reduce specific risk
- ~~pressposing~~, unauthorized access

Encryption :- converting data to cypher text

Authentication :- verifying who someone is

Authorization :- granting the permission

CIA triad core security model

A model how organisation consider risk setting up a system and policy

NIST framework

CSF -> A voluntary framework consist of standards, guidelines and best practice to manage security risk.

Six core function
- govern
- identify
- Protect
- detect
- Respond
- Recover

Identify: the management of cybersecurity risk and its effect on a organizations people and assets

- Protect -> strategy by implementing of policy procedures, training and tools that help mitigate cybersecurity threat

- detect: Identify potential security risk & incidents

- Respond: proper procedure use to contain and analyze the incident

- Recover: Return affected system back to business

OWASP - Principal

1. minimize attack surface area
2. Principal of least privilege
3. Defense in Depth
4. Separation of Duties
5. Keep Security simple
6. Fix security issues correctly
7. Establish secure defaults
8. Fail Securely
9. Dont trust services
10. Avoid security by Obscurity

Plan a Security Audit

- Review of an organizations security controls policies, and procedure against set of expectation

two type
- External
- Internal

Purpose

- Identify risk
- Assess controls
- correct compliance issues

Elements

- establishing the scope & goal
- conducting risk assessment
- controls assessment
- Assessing compliance
- Communicating result

Scope - specific criteria of an internal security audit

Goal - outline

control assessment :- closely reviewing existing assets and potential risk
- administrating
- Physical
- Technical

Compliance :- Laws must be followed

Asset: An item perceived as having value to an organization

Attack vectors: The pathways attackers use to penetrate security defenses

Authentication: The process of verifying who someone is

Authorization: The concept of granting access to specific resources in a system

Availability: The idea that data is accessible to those who are authorized to access it

Biometrics: The unique physical characteristics that can be used to verify a person's identity

Confidentiality: The idea that only authorized users can access specific assets or data

Confidentiality, integrity, availability (CIA) triad: A model that helps inform how organizations consider risk when setting up systems and security policies

Detect: A NIST core function related to identifying potential security incidents and improving monitoring capabilities to increase the speed and efficiency of detections

Encryption: The process of converting data from a readable format to an encoded format

Govern: A NIST core function related to ensuring an organization establishes, oversees, and improves its cybersecurity strategy, policies, roles, and risk management processes to align with business goals and regulations

Identify: A NIST core function related to management of cybersecurity risk and its effect on an organization's people and assets

Integrity: The idea that the data is correct, authentic, and reliable

National Institute of Standards and Technology (NIST) Cybersecurity Framework (CSF): A voluntary framework that consists of standards, guidelines, and best practices to manage cybersecurity risk

National Institute of Standards and Technology (NIST) Special Publication (S.P.) 800-53: A unified framework for protecting the security of information systems within the U.S. federal government

Open Web Application Security Project/Open Worldwide Application Security Project (OWASP): A non-profit organization focused on improving software security

Protect: A NIST core function used to protect an organization through the implementation of policies, procedures, training, and tools that help mitigate cybersecurity threats

Recover: A NIST core function related to returning affected systems back to normal operation

Respond: A NIST core function related to making sure that the proper procedures are used to contain, neutralize, and analyze security incidents, and implement improvements to the security process

Risk: Anything that can impact the confidentiality, integrity, or availability of an asset

Security audit: A review of an organization's security controls, policies, and procedures against a set of expectations

Security controls: Safeguards designed to reduce specific security risks

Security frameworks: Guidelines used for building plans to help mitigate risk and threats to data and privacy

Security posture: An organization's ability to manage its defense of critical assets and data and react to change

Threat: Any circumstance or event that can negatively impact assets

Module 3

- Logs
- SEIM dashboards
- Common SEIM Tools

Log :- A record of events that occur within in organization network

Log Source
- Firewall logs
- Network logs
- server logs

A firewall log is a record of attempted or established connection for incoming trafic from internet also include outbound requests.

Network log is record of all computer and device that enter and leave the network records connection between devices

Server log record of event related to service website, email,

Security information and event management [SEIM] tool :- an application that collect and analyze the log data and present in easy way to monitor critical activities

Can also be used to create dashboard

Types of SEIM Tool

- self hosted
  - Ideal for confidential
- Cloud-hosted
  - do not want to invest
- Hybrid

splunk, Chronicle

splunk Enterprise :- self hosted tool used to retain, analyze and search an organization's log data to provide security information and alert in real-time

splunk Cloud :- is a cloud hosted tool use to collect search or monitor data

google chronikal

Suricata :- an open source network analysis tool and threat detection software

Module - 4

Playbook that provide details about any operational action.

Incident response is organizations quick attempt to identify an attack, contains the damage and corrects the effects of security breach

Phases

- preparation - sets foundation
- Detection and analysis :- wether it has occurs
- Containment
- Eradication : remove malicious code
- Post incident activity
- Coordination : share